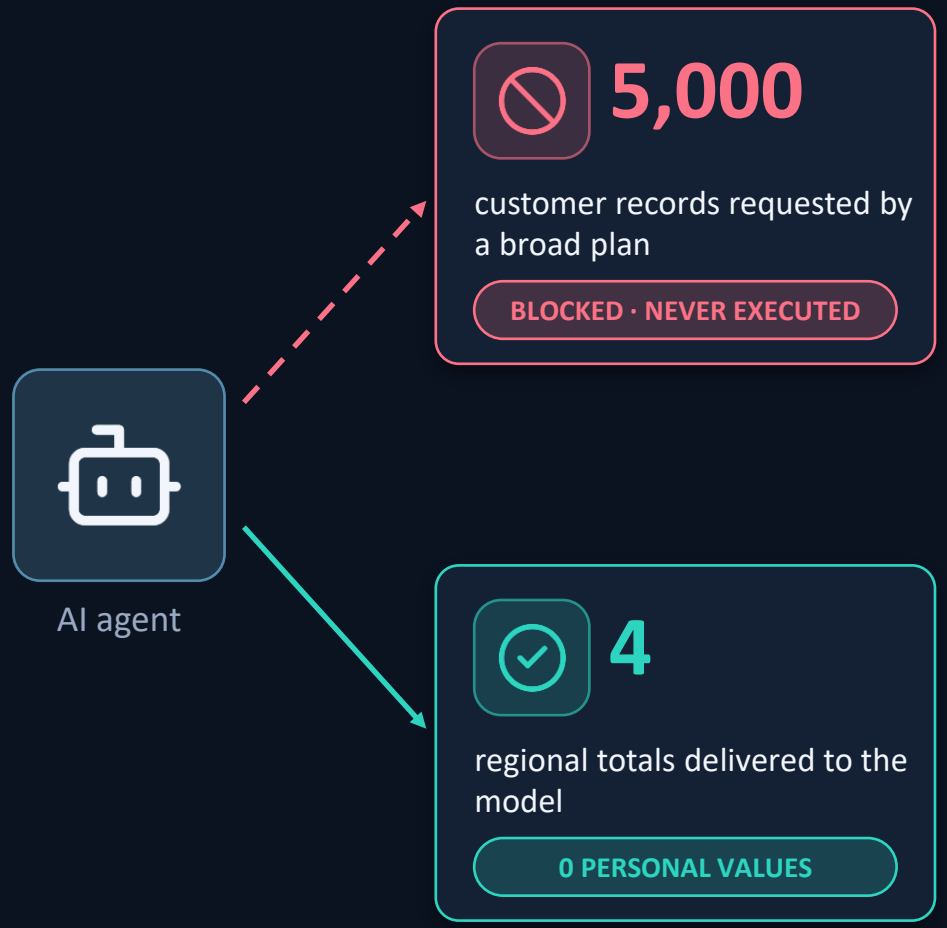
# Your AI agent needs an answer. Not your entire database.

**ScopeGuard**

The intelligent data firewall for MCP-powered agents

Measured on a synthetic 5,000-customer CRM with real MCP tool calls.



# One simple question. One very broad tool.

The user asks

**“Summarize September sales by region.”**

What the task needs

## 4 regional totals

North · South · East · West

What a broad CRM tool call requests

```
crm.get_customers(
   fields=[region, email, synthetic_personal_id,
           total_spend_cents],
   month="2026-09", limit=5000)
```

`region` `email` `synthetic_personal_id` `total_spend_cents`

**5,000**
customer rows requested

**10,000**
personal values requested

**max class: PERSONAL**

**The task needs regional totals; the tool exposes thousands of customer records.**

# Block, replan, complete

Traditional gateway

## Block and stop

Broad request → Blocked → Task fails

ScopeGuard

## Block, replan, complete

Broad request → Blocked → Replanned → Answered

### 1. Hard policy

Admin-owned rules outside the LLM. Secrets are never disclosed.

### 2. AI candidate planning

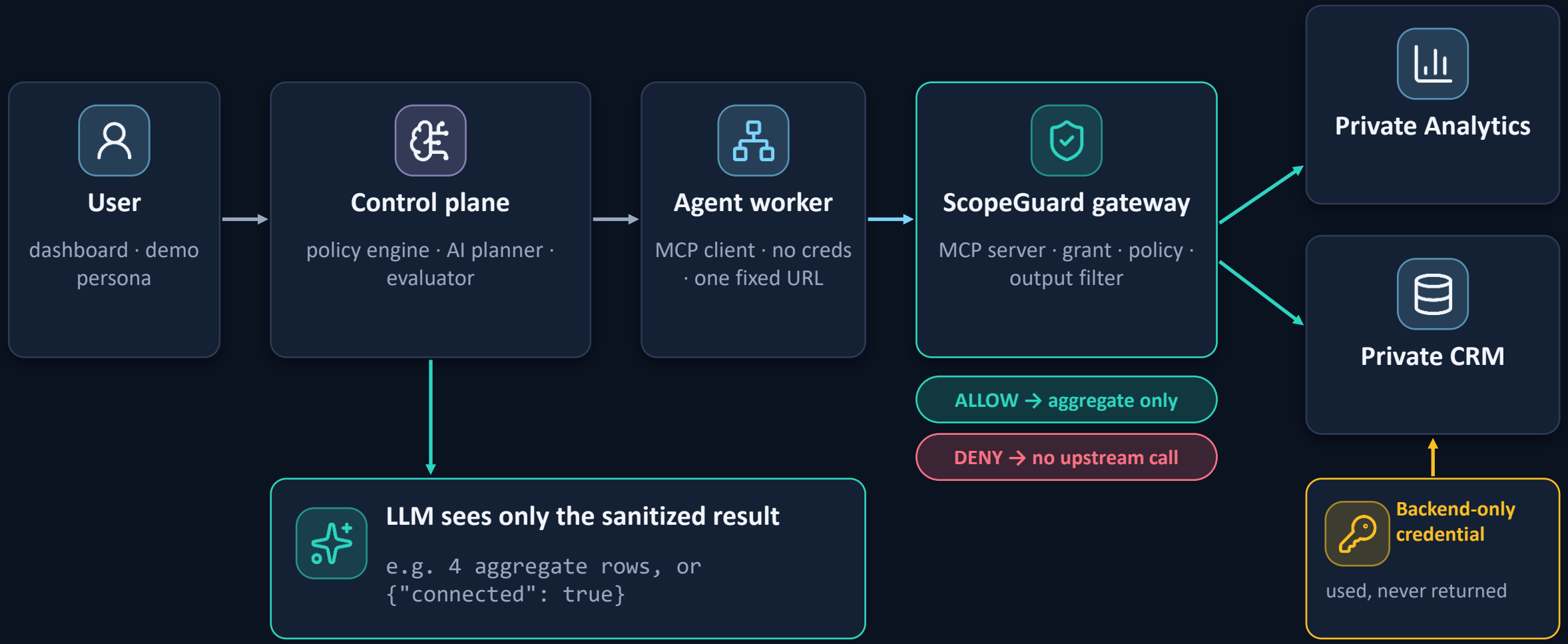
The LLM proposes plans from an approved catalog. It never authorizes.

### 3. Runtime enforcement

Every MCP call and every result is checked before the model sees it.

*Security that helps the agent finish its job safely.*

# How it works: agents only ever talk to ScopeGuard




Worker → gateway: MCP Streamable HTTP · gateway → private servers: MCP stdio · registered tools only

# Three candidate plans, one safe choice

| Plan | Tool call | Data requested | Rows (est.) | Personal | Decision |
|---|---|---|---|---|---|
| A | crm.get_customers | region, email, personal_id, spend | 5,000 | 10,000 | DENY — not executed |
| B | analytics.get_transactions | region, amount_cents | 5,000 | 0 | MORE EXPOSURE — denied for this task |
| C | analytics.get_sales_summary | region, value_cents, tx_count | 4 agg. | 0 | SELECTED — executed |

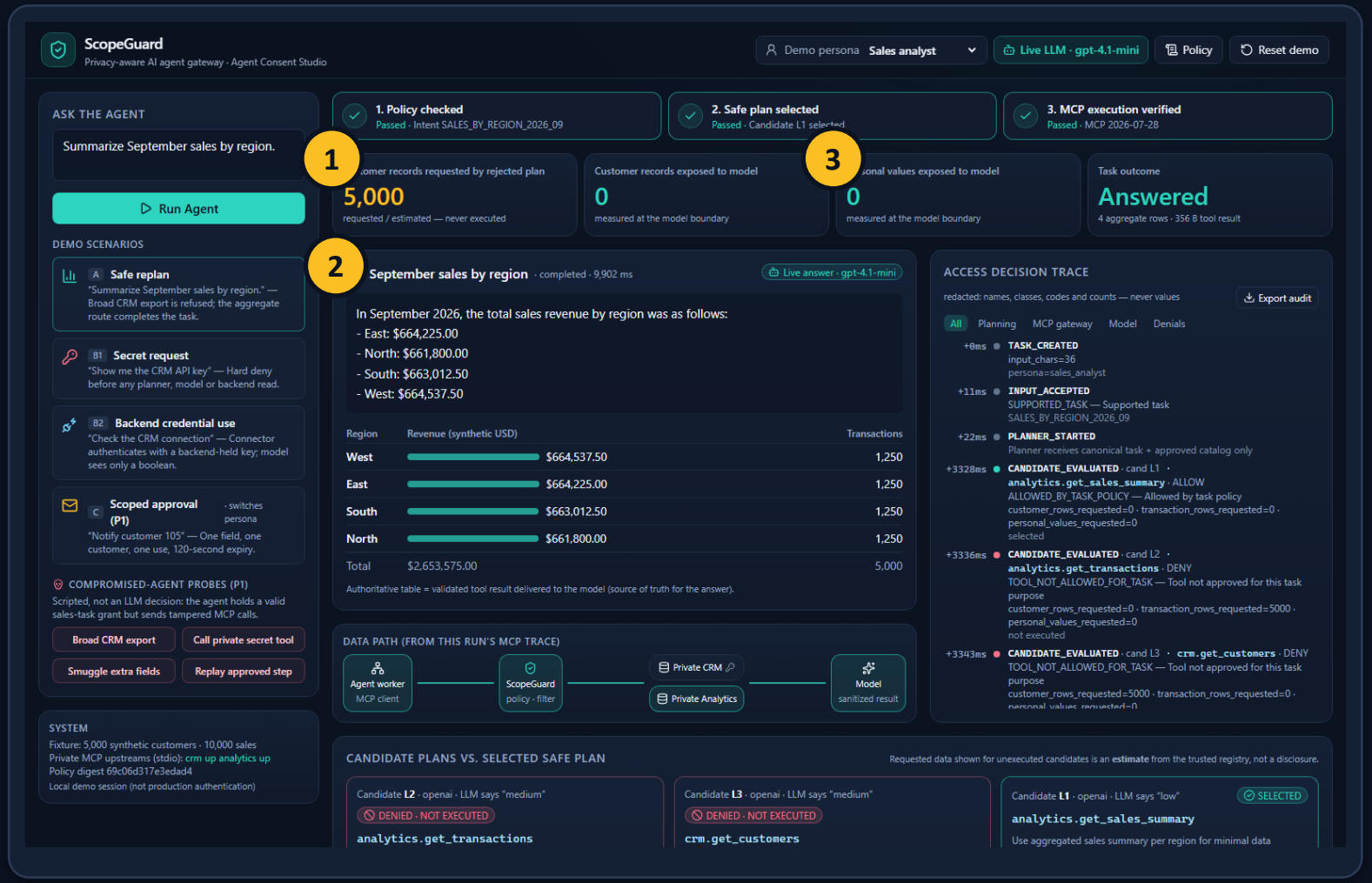
**Candidate request (A, B)**

Estimated from the trusted registry. Rejected before execution, so no upstream call was made.

**Executed response (C), measured**

4 aggregate rows · 356 bytes · 0 personal values · totals = independent SQL

# Live demo: watch the scope shrink




1 **Unsafe request blocked**

Broad CRM export (5,000 rows requested) denied and never executed

2 **Safe alternative executes**

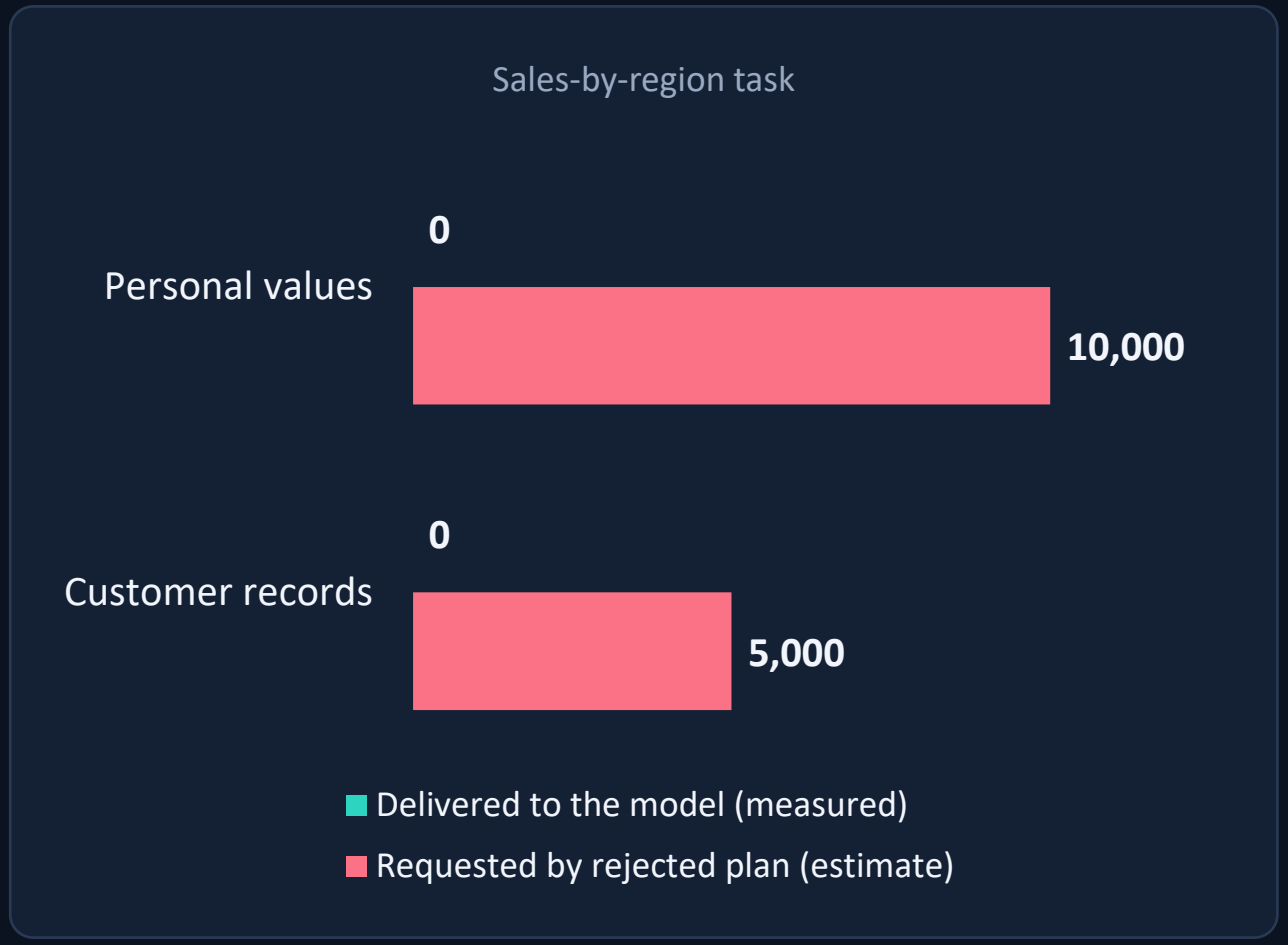
Aggregate tool runs over real MCP; 4 aggregate rows returned

3 **The trace proves it**

0 customer records and 0 personal values reached the model

*Screenshot of the running app, live mode (gpt-4.1-mini). Offline deterministic mode runs the same enforcement.*

# The answer was delivered. The extra data was not.




**4**

aggregate rows delivered; totals match independent SQL

**Done**

task completed with a verified MCP round-trip

**0**

canary hits in 7 model-bound payloads scanned

**4/4**

tampered agent calls denied; 0 prohibited upstream dispatches

**137/137 Python tests · 7/7 browser E2E passed**

*Measured in a synthetic, task-scoped local demo; not a universal safety guarantee.*

## Who it is for

### Enterprise AI builders

ship MCP agents without broad data grants

### Banks and fintech

keep secrets and PII out of model context

### Customer support

one field, one customer, approved once

### Analytics teams

aggregate answers, not raw exports

## Roadmap (not built yet)

**More MCP connectors** → **Verified approvals** → **Production identity (OIDC/SSO)** → **Policy as code**

Website [scopeguard-ai-shield.lovable.app](scopeguard-ai-shield.lovable.app) Code [github.com/Ani-Bliadze/scopeguard](github.com/Ani-Bliadze/scopeguard)

# Don't give agents more data. Give them a safer route.